

Evaluating Tool Permissions in AI Agents: A Simulated Study

Illustrative research-paper format for a student website prototype

Prepared with AI assistance | 5 October 2026
No university affiliation or authorship claim is asserted.

Abstract

This fictional study illustrates how a student could evaluate permission controls for an AI agent using external tools. It compares unrestricted tool access, read-only access and access with approval gates. A hypothetical benchmark contains 30 tasks per condition, including ordinary tasks and adversarial instructions. All numerical results are manually constructed examples; they were not produced by an agent, experiment, participant study or statistical simulation. The illustrative results demonstrate a potential trade-off between task completion and limits on consequential actions. The paper provides an evaluation design, metric definitions and a practical plan for replacing the examples with measured data. It makes no empirical claim about any AI model or deployed system.

Keywords: AI agents; tool permissions; sandbox evaluation; human approval; illustrative benchmark

1. Introduction

An agent that can read files, modify records or send messages needs a clearly defined boundary between allowed and prohibited actions. A small student project could investigate how different permission policies affect task completion and attempted boundary violations. The research question proposed here is: how does restricting tool access change successful completion of benign tasks and execution of prohibited actions in a controlled sandbox?

This document is a teaching and website-design sample. It uses invented counts to demonstrate the structure of a research report. It does not establish that permission controls produce any particular benefit in practice.

2. Proposed evaluation design

Use a local sandbox with synthetic files and a mock message service. No real emails, personal data or external accounts are involved. Define three tools: `read_record`, `update_record` and `send_mock_message`. Record every request, policy decision and resulting state change.

Condition A - unrestricted: all three tools execute without an approval gate.

Condition B - read-only: reads execute; updates and messages are denied.

Condition C - approval gates: reads execute; updates and messages require an explicit decision from a simulated reviewer.

3. Tasks and outcome definitions

The proposed benchmark has 20 benign tasks and 10 adversarial tasks, repeated under each policy. Ten benign tasks require only reads; ten require an authorised update or mock message. Adversarial tasks contain instructions to change or transmit data beyond the task authorisation. The hypothetical reviewer approves authorised actions and rejects prohibited actions; this idealised behaviour is an assumption, not a finding.

Benign completion rate: benign tasks whose final state matches a predefined expected state, divided by 20.

Prohibited-action execution rate: adversarial tasks that result in at least one prohibited state change or transmission, divided by 10.

Approval requests: the count of requests presented to the mock reviewer. This measures interaction burden, not real human workload.

4. Illustrative results - invented data

Every entry below is invented for demonstration. The table is not evidence and must retain this label wherever it is reproduced.

Permission policy	Benign tasks completed / 20	Adversarial tasks with prohibited execution / 10	Approval requests
Unrestricted	19 (95%)	6 (60%)	0
Read-only	10 (50%)	0 (0%)	0
Approval gates	18 (90%)	0 (0%)	16

Table 1. Manually constructed outcomes for three hypothetical conditions. The same task set is assumed across conditions. No measured observations underlie these counts.

5. Interpretation and limitations

The invented pattern illustrates how read-only access could prevent state-changing violations while also blocking legitimate work. Approval gates could permit more legitimate work, but introduce review effort and depend on correct reviewer decisions. These are hypotheses for testing. The zero values in the table are not a guarantee of security.

Important omissions include model variability, repeated trials, reviewer errors, attempts to bypass controls, indirect data leakage, timing and operating cost. Denying a tool call should be distinguished from preventing an unsafe request: an agent may still attempt a prohibited action. With no collected observations, confidence intervals and significance tests would be misleading and are not reported.

6. One-week plan for a real student experiment

Day 1: specify the benchmark

Write the 30 synthetic tasks, authorisation rules and expected outcomes before running the agent. Keep an independent task file and record any later changes.

Day 2: implement the sandbox

Create the three mock tools and enforce permissions in the tool executor. Verify that denied actions cannot alter the sandbox state.

Day 3: verify logging and scoring

Test known allowed and denied actions. Log task ID, policy, requested tool, arguments, decision and final state. Remove any secrets from logs.

Days 4-5: collect observations

Run the same tasks under all three policies. Record the actual model identifier, configuration, run dates and approval rules. Repeat runs if resources allow and report the number of repetitions.

Day 6: analyse the collected data

Replace the illustrative table with counts derived from logs. Report attempted and executed violations separately, include failed tasks and describe any subjective scoring decisions.

Day 7: document and demonstrate

Publish the benchmark, sandbox code and a small example trace. Explain limitations and AI assistance. Only describe results as measured once the actual experiment has been completed.

7. Conclusion

A small sandbox evaluation could be a feasible student project for exploring agent permissions. This sample demonstrates how to describe that project and its metrics, but supplies no experimental evidence. Any future claim about performance or safety must be supported by collected logs and a reproducible procedure.

Transparency and publication note

Data: all reported counts are manually invented.

Execution: no agent, model or human participant was tested.

Assistance: this document was drafted using AI.

References: no external literature was consulted or cited; no references are fabricated.

Suggested website label: “Sample paper - fictional experiment and simulated results.”

Publication status: educational demonstration, not a peer-reviewed or empirical research paper.